

מודול 6 — סריקה, מיפוי והערכת חולשות

חומר לימוד

1 יחידות

תוכן העניינים

1. מודול 6 — סריקה, מיפוי והערכת חולשות (Scanning & Enumeration)

מודול 6 — סריקה, מיפוי והערכת חולשות (Scanning & Enumeration)

מטרות המודול: לעבור מ-Recon פסיבי לסריקה **אקטיבית** — לשלוט ב-Nmap לעומק, למנות שירותים (HTTP/HTTPS, SMB, SSH, FTP), להריץ סריקת חולשות עם **Nessus**, ולחקור חולשות עם **Searchsploit / Exploit-DB**. זהו השלב שממפה את משטח התקיפה ומזהה את נקודות הכניסה.

קבצים: `slides.md` · `practice.md` · `solutions.md` · `missions.md` · `README.md`

מבוסס על שיעורי המקור #47–#39 (Kioptrix + Nmap, Enumerating HTTP/SMB/SSH, Researching) (Vulnerabilities, Nessus).

המקום בשרשרת: שלב 2 מחמשת השלבים. אחרי שמפינו את היעד (מודול 5), עכשיו נוגעים בו ישירות — מוצאים פורטים, שירותים, גרסאות וחולשות. ככל שהמנייה יסודית יותר, כך הניצול (מודול 7) קל יותר.

תוכן העניינים

1. שלב הסריקה — סקירה
2. Nmap — יסודות וגילוי מארחים
3. Nmap לעומק
4. מניית HTTP/HTTPS
5. מניית SMB
6. מניית SSH ו-FTP
7. סריקת חולשות עם Nessus
8. חקר חולשות
9. ארגון הערות

6.1 שלב הסריקה — סקירה

בעוד Recon פסיבי נמנע ממגע, הסריקה היא **אקטיבית** — שולחים חבילות ליעד ומנתחים את התגובות. שני מושגים: **Scanning** — מציאת מכונות חיות ופורטים פתוחים. - **Enumeration (מנייה)** — חפירה עמוקה

בכל שירות שנמצא: גרסה, הגדרות, משתמשים, שיתופים, ספריות.

כלל הזהב של המנייה: "Enumerate, enumerate, enumerate" מהעבודה כאן. כל פורט פתוח = שירות = חולשה פוטנציאלית. אל תמהר לניצול לפני מנייה יסודית.

מכונת התרגול בקורס: **Kioptrix Level 1** (מ-VulnHub) — מכונה פגיעה בכוונה, מצוינת לתרגול. הורד, טען ב-VirtualBox (או VMware) באותה רשת (Host-Only) כמו Kali.

Nmap 6.2 — יסודות וגילוי מארחים

Nmap (Network Mapper) הוא הכלי המרכזי לסריקה. נתחיל בגילוי מארחים (מי חי ברשת):

```
nmap -sn 192.168.1.0/24 # Host Discovery בלבד (ping sweep), ללא סריקת פורטים
```

סריקת פורטים בסיסית על יעד:

```
nmap 192.168.1.10 # הפורטים הנפוצים 1000
nmap -p- 192.168.1.10 # כל 65,535 הפורטים (איטי אך יסודי)
nmap -p 80,443,445 192.168.1.10 # פורטים ספציפיים
nmap -F 192.168.1.10 # מהיר (100 פורטים)
```

סוגי סריקה עיקריים

דגל	סוג	הערה
-sS	SYN Scan	ברירת מחדל (דורש root), מהיר ו"חצי-פתוח"
-sT	TCP Connect	לחיצת יד מלאה (ללא root)
-sU	UDP Scan	לשירותי UDP (DNS, SNMP), איטי
-sn	ללא סריקת פורטים	גילוי מארחים בלבד

קשר למודול 3: -sS שולח SYN ומנתח את התשובה (SYN-ACK=פתוח, RST=סגור) — בדיוק מנגנון לחיצת היד שלמדנו.

Nmap 6.3 לעומק — שירותים, גרסאות ו-NSE

מציאת פורט פתוח היא רק ההתחלה. עכשיו ממנים אותו:

```
nmap -sV 192.168.1.10      # Version Detection – גרסאות השירותים
nmap -O 192.168.1.10      # Operating System detection
nmap -sC 192.168.1.10     # סקריפטים ברירת מחדל (NSE)
nmap -A 192.168.1.10     # :אגרסיבי -sV -O -sC + traceroute
```

הסקריקה המומלצת להתחלה (משלב הכל):

```
nmap -sC -sV -oN scan.txt 192.168.1.10
```

• -sC סקריפטים • -sV גרסאות • -oN scan.txt שמירת פלט לקובץ.

דוגמת פלט וקריאתה

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 2.9p2 (protocol 1.99)
80/tcp	open	http	Apache httpd 1.3.20 ((Unix) mod_ssl/2.8.4)
139/tcp	open	netbios-ssn	Samba smbd
443/tcp	open	ssl/http	Apache/1.3.20

כל שורה = יעד פוטנציאלי. שים לב לגרסאות הישנות (Apache 1.3.20, OpenSSH 2.9) — אלה מובילים לחולשות ידועות (סעיף 6.8).

NSE — Nmap Scripting Engine

```
nmap --script vuln 192.168.1.10      # חיפוש חולשות ידועות
nmap --script smb-enum-shares 192.168.1.10
nmap -p 445 --script smb-vuln-ms17-010 192.168.1.10 # בדיקת EternalBlue
```

הסקריפטים ב- `/usr/share/nmap/scripts/`.

שמירת פלט

```
nmap -sC -sV -oA fullscan 192.168.1.10 # -oA = כל הפורמטים (.nmap/.gnmap/.xml)
```

6.4 מניית HTTP/HTTPS

אם פורט 80/443 פתוח — יש שרת web. זהו לרוב משטח התקיפה הגדול ביותר.

```
whatweb http://192.168.1.10      # זיהוי טכנולוגיות
nikto -h http://192.168.1.10    # נפוצות web סורק חולשות
```

גילוי ספריות וקבצים נסתרים (Directory Brute-Force)

```
gobuster dir -u http://192.168.1.10 -w /usr/share/wordlists/dirb/common.txt
# חלופות:
dirb http://192.168.1.10
feroxbuster -u http://192.168.1.10
```

מחפש נתיבים נסתרים כמו `./robots.txt` , `/config` , `/backup` , `/admin`

בדיקה ידנית

- גלוש לאתר, קרא את קוד המקור (Ctrl+U), חפש הערות ונתיבים.
- בדוק את `./robots.txt` ו- `./sitemap.xml`
- זוהה את גרסת שרת ה- (Web (Header Server: — יעד לחיפוש Exploit.

💡 **HTTP מול HTTPS:** בדוק את **שניהם** (80 ו-443) — לעיתים הם מגישים תוכן שונה, ו-HTTPS עשוי לחשוף פרטים בתעודת ה-SSL (שמות דומיין, מיילים).

6.5 מניית SMB

SMB (Server Message Block) — פרוטוקול שיתוף קבצים של Windows, על פורטים **139/445**. נפוץ מאוד ברשתות פנימיות, ומקור לחולשות חמורות.

```
enum4linux -a 192.168.1.10      # מנייה מקיפה (משתמשים, שיתופים, קבוצות)
smbclient -L //192.168.1.10/    # רשימת שיתופים (Shares)
smbclient //192.168.1.10/share  # התחברות לשיתוף
nmap -p 139,445 --script smb-enum-shares,smb-enum-users 192.168.1.10
```

חולשות SMB מפורסמות

- **MS17-010 (EternalBlue)** — חולשה קריטית ששימשה במתקפת **WannaCry**. עדיין נמצאת במערכות רבות.

```
nmap -p 445 --script smb-vuln-ms17-010 192.168.1.10
```

• **SMB Null Session** — התחברות ללא אימות, חושפת משתמשים ושיתופים.

🔍 כשאתה רואה SMB בסריקה — **חשוב "רשת פנימית ארגונית"**. זהו אחד הווקטורים המרכזיים לתנועה רוחבית (מודול 12) ו-Active Directory (מודול 13).

6.6 מניית SSH ו-FTP

SSH (פורט 22)

```
nmap -p 22 -sV 192.168.1.10      # גרסת OpenSSH
ssh user@192.168.1.10          # ניסיון התחברות
```

גרסה ישנה = חולשה אפשרית. SSH הוא גם יעד מרכזי ל-**Brute Force** (מודול 8).

FTP (פורט 21)

```
nmap -p 21 -sV --script ftp-anon 192.168.1.10  # בדיקת התחברות אנונימית
ftp 192.168.1.10                                # user: anonymous נסה
```

• **Anonymous FTP** — אם מאופשר, מאפשר גישה לקבצים ללא סיסמה — פרס נפוץ.

6.7 סריקת חולשות עם Nessus

Nessus הוא סורק חולשות אוטומטי (מבית Tenable) — מזהה אלפי חולשות ידועות ומדרג אותן לפי חומרה. הגרסה **Nessus Essentials** חינמית (עד 16 כתובות IP).

התקנה והרצה

1. מ-tenable.com - הורד את חבילת ה-.deb
2. `sudo dpkg -i Nessus-*.deb`
3. `sudo systemctl start nessusd`
4. Essentials צור חשבון ← `https://localhost:8834` - גלוש ל
5. Launch → של היעד IP-הון את ה → New Scan → Basic Network Scan

Nessus מדרג ממצאים: **Critical / High / Medium / Low / Info**, כל אחד עם תיאור, CVE, ותיקון מומלץ.

⚠ **חשוב:** Nessus הוא כלי רועש — הוא שולח הרבה תעבורה. הרץ רק על יעדים מורשים, ואל תסתמך עליו לבד — סריקה אוטומטית מפספסת חולשות לוגיות שרק מנייה ידנית תמצא.

6.8 חקר חולשות (Searchsploit / Exploit-DB)

מצאת שירות בגרסה מסוימת — עכשיו מחפשים אם יש לו Exploit ידוע.

```
searchsploit apache 1.3.20      # Exploit-DB חיפוש מקומי במאגר
searchsploit -m 764             # לתיקיה הנוכחית Exploit העתקת
searchsploit openssh 2.9
```

- **Exploit-DB** (exploit-db.com) — מאגר ה-Exploits הגדול; `searchsploit` הוא העותק המקומי ב-Kali.
- **CVE** (Common Vulnerabilities and Exposures) — מזהה ייחודי לכל חולשה (למשל CVE-2017-0144 = EternalBlue). חפש ב-cve.mitre.org או nvd.nist.gov.

🔍 **הזרימה המלאה:** `searchsploit apache 1.3.20` → `nmap -sV` מגלה `Apache 1.3.20` → מוצא Exploit → נשמור אותו לשלב הניצול (מודול 7). זהו הגשר בין מנייה לניצול.

6.9 ארגון הערות

בבדיקה אמיתית תצבור מידע רב. **תיעוד מסודר הוא קריטי** — גם לניצול, גם לדוח הסופי (מודול 16).

- כלים: **CherryTree**, **Obsidian**, **Joplin**, או פשוט תיקיית Markdown.
- מבנה מומלץ לכל יעד: IP → פורטים פתוחים → שירותים וגרסאות → ממצאי מנייה → חולשות אפשריות → פקודות שהרצת.
- **צלם מסך** של כל ממצא חשוב — תזדקק לזה לדוח.

💡 **הרגל מקצועי:** פתח קובץ הערות לכל יעד **לפני** שאתה מתחיל, והדבק אליו כל פלט תוך כדי. עדיף מדי-מפורט מאשר לשכוח איך הגעת לממצא.

סיכום המודול

- **Nmap** הוא הליבה: `-sn` לגילוי מארחים, `-p -sV -sC` למנייה מלאה, `--script` ל-NSE.
- **מנייה לפי שירות:** HTTP (nikto, gobuster), SMB (enum4linux, smbclient, MS17-010), SSH/FTP (גרסאות, anonymous).
- **Nessus** לסריקת חולשות אוטומטית — כלי עזר, לא תחליף למנייה ידנית.
- **Searchsploit / Exploit-DB / CVE** מגשרים בין גרסה שנמצאה ל-Exploit — הכניסה לשלב הניצול.
- **תעד הכל** — לניצול ולדוח.

מה הלאה?

→ **missions.md** — פתרונות — **solutions.md** · תרגול ותרחישים — **practice.md** →
מודול 7 — ניצול והשגת גישה

← חזרה למפת הקורס